TalentStroom

Juridische briefing: privacy, AVG en AI Act

Voor: privacy- en IT-jurist · Fase 0 · issues #10–#15 · versie 1.0 · 28 oktober 2026 · vertrouwelijk concept

> Deze briefing beschrijft ons product en onze **aannames**. Het is uitdrukkelijk geen juridisch advies; we vragen u die aannames te toetsen. Waar we wetgeving of richtlijnen noemen, graag controleren of die nog actueel zijn.

1. Wat we van u vragen

Wij bouwen TalentStroom, software (SaaS) voor recruitmentbureaus. Voordat we echte kandidaatgegevens verwerken (een private alpha met 2–3 bureaus), willen we de juridische basis op orde hebben. We vragen advies over zes onderwerpen (hoofdstuk 5) en de volgende producten:

#	Product	Nodig vóór
1	Memo rolverdeling verwerkingsverantwoordelijke / verwerker per verwerking	Private alpha
2	Verwerkersovereenkomst (model) inclusief subverwerkerslijst en beveiligingsbijlage	Private alpha
3	Uitkomst DPIA-screening en, indien nodig, aanpak DPIA	Private alpha
4	Memo AI Act-classificatie van de AI-functies in de eerste versie	Private alpha
5	Advies over standaard bewaartermijnen die wij in de software voorstellen	Private alpha
6	Advies datalocatie en doorgiftes (EU of alleen NL)	Private alpha
7	Beleid voor bijzondere persoonsgegevens en BSN in cv's	Private alpha
8	Privacyverklaring, algemene voorwaarden en pagina verwerkersovereenkomst voor de website	Gesloten bèta

Graag vooraf een inschatting van tijd en kosten, en welke punten u eventueel zou laten vervallen.

2. Het product in het kort

- **Klanten:** Nederlandse werving- en selectiebureaus en headhunters met 2–10 recruiters (IT, techniek, finance, executive search). Geen interne HR-afdelingen van werkgevers.
- **Gebruikers:** recruiters en bureau-eigenaren. Eén persoon kan lid zijn van meerdere bureaus (organisaties) en kiest na het inloggen expliciet de actieve organisatie.
- **Kernfuncties:** kandidaten en cv's beheren; vacatures en opdrachtgevers; per vacature een pipeline met fases; taken en herinneringen; plaatsingen met fee.
- **Delen met opdrachtgevers:** de recruiter kiest welke velden en cv's zichtbaar zijn, maakt daarvan een vaste momentopname en deelt die via een **verlopende, intrekbare link**. De opdrachtgever heeft geen account, bekijkt de kandidaten en geeft een beoordeling en feedback.

- **AI-hulp (altijd met menselijke controle):** cv uitlezen naar een concept-profiel dat de recruiter controleert; teksten vertalen Nederlands↔Engels; concepten schrijven (vacaturetekst, e-mail); samenvatting van notities.
- **Bewust niet in de eerste versie:** kandidaten rangschikken, scoren of automatisch selecteren; profilering; scrapen van internet; automatisch e-mails versturen; inbox-synchronisatie.
- **Maatwerkmodules:** een beheerder van het bureau kan eigen gestructureerde velden toevoegen (bijv. "IT-profiel"). Geen eigen code.

3. Gegevensverwerkingen en voorgestelde rollen

Verwerking	Betrokkenen	Gegevens	Onze aanname over de rol van TalentStroom
Kandidaatbeheer, pipeline, plaatsingen	Kandidaten	NAW, contact, cv, werkervaring, opleiding, vaardigheden, notities, status per vacature, salaris/tarief; incidenteel bijzondere gegevens in cv's	Verwerker voor het bureau
Opdrachtgevers en contactpersonen	Contactpersonen bij opdrachtgevers	Naam, functie, zakelijk e-mailadres en telefoonnummer	Verwerker voor het bureau
Shortlist delen en feedback	Kandidaten; beoordelaars bij opdrachtgever	Door recruiter gekozen velden en cv; beoordeling, keuze, opmerking; naam beoordelaar (optioneel); toegangslogs	Verwerker voor het bureau
AI-functies	Kandidaten, gebruikers	Minimale tekst nodig voor de taak (bijv. cv-tekst), uitkomst, gebruikte model en goedkeuring	Verwerker; AI-leverancier als subverwerker
Gebruikersaccounts, beveiliging, facturatie	Gebruikers (recruiters, eigenaren)	Naam, e-mail, inlogmethoden, beveiligingslogs, abonnement	Verwerkingsverantwoordelijke
Productanalyse en support	Gebruikers	Gebruiksstatistieken zonder kandidaatgegevens, supportverzoeken	Verwerkingsverantwoordelijke

4. Belangrijkste maatregelen (samenvatting)

- **Versleuteling per record:** persoonsgegevens van kandidaten en documenten worden in de applicatie versleuteld met een eigen sleutel per record. De hoofdsleutels staan in een aparte sleuteldienst (KMS), niet in de database. Een gestolen database alleen is daardoor onleesbaar.
- **Scheiding tussen bureaus:** elk verzoek wordt gecontroleerd op lidmaatschap van de actieve organisatie, met daarnaast afscherming in de database zelf.
- **Gedeelde links:** alleen een hash van de link wordt opgeslagen; links verlopen en zijn direct in te trekken; alleen de goedgekeurde momentopname is zichtbaar.
- **Inloggen:** voorkeur voor passkeys en MFA; automatische vergrendeling bij inactiviteit.

- **AI:** alleen via de server, met minimale gegevens, bij leveranciers die niet trainen op klantdata; uitkomsten zijn altijd een concept dat de gebruiker goedkeurt; AI is per bureau uit te zetten.
- **Rechten van betrokkenen:** export, verwijderen (inclusief documenten, momentopnames en vertalingen) en bewaartermijnen met een beoordelingslijst.
- **Hosting (voorlopig):** applicatie op Cloudflare Workers, database bij een beheerde PostgreSQL-dienst in de EU, bestanden in Cloudflare R2 (EU), sleutelbeheer bij een EU-KMS. Definitieve leveranciers worden nog gekozen.

5. Vragen per onderwerp

5.1 Rolverdeling verwerkingsverantwoordelijke / verwerker (issue #10)

1. Klopt het dat het bureau verwerkingsverantwoordelijke is voor kandidaat-, opdrachtgever- en feedbackgegevens, en TalentStroom verwerker?
2. Welke rol heeft de opdrachtgever die via een link kandidaten bekijkt en feedback geeft? Ontvanger, zelfstandig verantwoordelijke of anders? Wat betekent dat voor onze feedbackfunctie?
3. Zijn wij voor gebruikersaccounts, beveiligingslogs, facturatie en geanonimiseerde productstatistieken terecht zelfstandig verwerkingsverantwoordelijke?
4. Mogen wij geaggregeerde, niet-herleidbare statistieken (bijv. aantallen gedeelde shortlists) gebruiken voor productontwikkeling? Onder welke voorwaarden?
5. Welk model verwerkersovereenkomst raadt u aan (bijv. het model van NL Digital) en hoe gaan we om met wijzigingen in subverwerkers?
6. Wat moet in de beveiligingsbijlage staan, en hoe concreet mogen onze beveiligingsclaims zijn zolang er nog geen externe audit is?

5.2 DPIA-screening (issue #11)

1. Valt het gebruik van TalentStroom door een bureau onder de verwerkingen waarvoor de Autoriteit Persoonsgegevens een DPIA verplicht stelt? Welke criteria zijn hier relevant (bijv. omvang, beoordeling van personen, nieuwe technologie, AI)?
2. De DPIA is een plicht van het bureau. Welke informatie moeten wij als verwerker aanleveren? Is een standaard "DPIA-ondersteuningsdocument" verstandig?
3. Adviseert u dat wij zelf een DPIA uitvoeren op het product, ook als dat niet verplicht is?

5.3 AI Act-classificatie (issue #12)

AI-systemen voor werving en selectie (o.a. sollicitaties analyseren en filteren, kandidaten beoordelen) worden in de AI-verordening als **hoog risico** aangemerkt. Onze eerste versie **rangschikt, scoort of filtert geen kandidaten**. De AI-functies zijn:

Functie	Wat het doet	Onze aanname
Cv uitlezen	Zet de tekst van een cv om in velden (naam, ervaring, opleiding, vaardigheden) als concept; de recruiter controleert en slaat op. Geen oordeel over geschiktheid.	Smalle, procedurele of voorbereidende taak; geen hoog risico. Graag toetsen.
Vertalen NL↔EN	Vertaalt vacatureteksten, samenvattingen en e-mails; origineel blijft bewaard; publicatie na goedkeuring.	Geen hoog risico.
Schrijfhulp	Concepten voor vacatureteksten en e-mails; nooit automatisch verzonden.	Geen hoog risico; mogelijk transparantieplicht.
Samenvatten	Vat notities en activiteit over een kandidaat samen, met verwijzing naar de bron.	Grensgeval? Graag toetsen.

1. Vallen deze functies buiten de hoog-risicocategorie, bijvoorbeeld via de uitzonderingen voor smalle procedurele of voorbereidende taken? Moeten wij die beoordeling documenteren of registreren?
2. Welke verplichtingen gelden dan wel (transparantie richting gebruikers, AI-geletterdheid, labeling van AI-uitkomsten)?
3. Zijn wij aanbieder en het bureau gebruiksverantwoordelijke ("deployer")? Wat moeten wij het bureau meegeven?
4. Welke termijnen gelden op dit moment, mede gezien eventuele uitstel- of wijzigingsvoorstellen?
5. Wat zou er veranderen als we later wél kandidaat-vacature-matching aanbieden (backlog, alleen na apart onderzoek)?

5.4 Bewaartermijnen (issue #13)

De AP noemt voor sollicitanten bij een werkgever circa 4 weken na afloop van de procedure, en tot 1 jaar met toestemming. Recruitmentbureaus bouwen echter een talentpool op voor toekomstige vacatures. De software zal bewaartermijnen per categorie voorstellen, herinneringen geven en een beoordelingslijst tonen; het bureau beslist.

1. Welke standaardtermijnen kunnen wij verdedigbaar voorstellen voor: (a) afgewezen kandidaat voor een specifieke vacature, (b) kandidaat in de talentpool zonder lopende procedure, (c) geplaatste kandidaat, (d) feedback van opdrachtgevers, (e) gedeelde momentopnames?
2. Welke grondslag past bij een talentpool (toestemming of gerechtvaardigd belang)? Hoe moet toestemming worden vastgelegd en vernieuwd?
3. Wat is de verwachting voor back-ups: is het acceptabel dat verwijderde gegevens maximaal [X] dagen in versleutelde back-ups blijven, met een register van verwijderingen dat bij herstel opnieuw wordt toegepast?
4. Is "cryptografisch wissen" (de sleutel van een record vernietigen) een aanvaardbare vorm van verwijderen?

5.5 Datalocatie en doorgiftes (issue #14)

1. Is opslag en verwerking binnen de EU voldoende, of verwacht u dat bureaus contractueel verwerking alleen in Nederland eisen?
2. Cloudflare voert code uit op een wereldwijd netwerk dicht bij de gebruiker; data-opslag kan op de EU worden ingesteld. Hoe beoordeelt u dit, en welke instellingen of afspraken zijn nodig?
3. Meerdere beoogde leveranciers hebben een Amerikaanse moederorganisatie. Wat is nodig om doorgiftes en toegang vanuit derde landen te beoordelen en vast te leggen (bijv. adequaatheidsbesluit, modelcontractbepalingen, doorgiftetoets)?
4. Welke eisen stelt u aan de AI-leverancier (EU-verwerking, geen training op data, bewaartermijn van prompts)?

5.6 Bijzondere persoonsgegevens en BSN (issue #15)

Cv's bevatten soms ongevraagd een BSN, pasfoto, nationaliteit, geboortedatum, gezondheidsinformatie, religie of lidmaatschappen. Wij willen dit in de software signaleren.

1. Mag een bureau een BSN uit een cv bewaren in de wervingsfase? Zo niet: moeten wij het automatisch maskeren of weigeren, of alleen waarschuwen?

2. Hoe moeten wij omgaan met overige bijzondere persoonsgegevens in cv's: waarschuwen, laten verwijderen, of ongewijzigd laten?
3. Is een pasfoto in een cv een bijzonder persoonsgegeven in deze context? Mogen we die tonen aan opdrachtgevers als de recruiter dat kiest?
4. Mag het automatisch signaleren van deze gegevens zelf (via AI) plaatsvinden, en onder welke voorwaarden?

5.7 Overige punten

1. **Merknaam (issue #9):** kunt u een merkenonderzoek naar "TalentStroom" (Benelux/EU) uitvoeren of iemand aanbevelen? Een eigen domeinnaam gebruiken we voorlopig niet.
2. **Datalekken:** welke afspraken over meldtermijnen tussen ons en het bureau raadt u aan?
3. **Aansprakelijkheid:** welke beperkingen zijn gebruikelijk voor kleine SaaS-leveranciers aan zakelijke klanten?
4. **Pilotovereenkomst:** wat moet minimaal geregeld zijn voor een gratis pilot met 2–3 bureaus?

---

6. Wat wij nog moeten regelen

- Rechtspersoon en contactgegevens voor de overeenkomsten: [in te vullen].
- Definitieve keuze van leveranciers (identiteit/inloggen, database, sleutelbeheer, AI, e-mail, betalingen); wij leveren dan een subverwerkerslijst aan.
- Een aanspreekpunt voor privacy binnen TalentStroom.

---

7. Achtergrondinformatie

Op verzoek sturen we (Engelstalige) documentatie mee:

- Productvisie en functionele eisen (PRD)
- Ontwerp versleuteling en sleutelbeheer
- Identiteit, beveiliging en privacy
- Procesbeschrijvingen: delen met opdrachtgevers, AVG-export en -verwijdering, sleutelrotatie

---